

감사결과 처분요구서

- 정보보안 관리실태 조사 -

2017. 4.

감 사 실

목 차

I . 감사 실시 개요	1
1. 감사 배경 및 목적	1
2. 감사 대상 및 범위	1
3. 감사 기간 및 인원	1
4. 감사 중점	2
 II . 감사결과 처분요구	3
1. 본사사옥 설비관리용 컴퓨터 계정 미분리 사용(경고)	4
2. △ 보안관리 미흡(주의, 통보)	6
3. 정보시스템 저장매체(HDD) 보안규정 미준수(경고)	8
4. DREAMS내 과도한 회사자료 다운로드 관리체계 개선(통보)	10
5. 시각동기화 설비 확대적용 방안 강구(통보)	11
6. 정보보안솔루션(5종) 개선(권고)	12

I . 감사실시 개요

1. 감사 배경 및 목적

- 「원전 안전운영을 위한 선제적 감사」를 통해, 미래 사이버 보안 위협 요소를 분석하고 개선사항을 도출하기 위함.

2. 감사대상 및 범위

- 全 社 : 정보보안 솔루션 로그기록 기반 감사
 - ※ 사업소 : 3개 소규모 사업소(◁, ▽, △)

3. 감사 기간 및 인원

- 감사기간 : 2017. 2. 13.(월)~같은 해. 3. 24.(금)
- 감사인원

기 간	대상 사업소	감사인원
2017. 2. 13.~2. 14.	◁	검사역 2명
2017. 2. 14.~2. 15.	▽	검사역 2명
2017. 2. 15.~2. 16.	△	검사역 2명
2017. 3. 6.~3. 10.	全 社	외부 전문가
2017. 3. 10.	本社(사옥)	검사역 1명, 외부전문가

※ 대량의 정보보안 솔루션 로그기록 분석 외부전문가(2명) 활용

4. 감사 중점

- 정보보안 솔루션 로그기록 기반 임직원 사용자 중심의 보안규정 준수여부
- 정부기관에 의한 정보보안 지적/권고사항 분석
- DREAMS를 이용한 과도한 자료 다운로드 者 적정성
- 주요 정보시스템 컴퓨터 설비에 대한 계정(ID) 분리 사용여부
- 정보시스템 설비 사고발생시 추적을 위한 시각동기화 설비 운용실태
- 3개 소규모 사업소장 보안규정 준수 실태
- 현장 실사 및 관련자 인터뷰를 통한 사실관계 확인 등

Ⅱ. 감사결과 처분요구

1. 처분요구사항 일람표

번호	관계부서	구분	제 목	처분요구 종 류	금 액 (인원/건)
1	●○	감찰	빌딩제어설비용 컴퓨터 계정 미분리 사용	경고	(2)
2	●○	감찰	빌딩제어설비용 컴퓨터 계정 분리	시정	(1)
3	◇	감찰	△ 보안관리 미흡	주의	(1)
4	● 目	감찰	정보시스템 저장매체(HDD) 데이터 삭제 관리·감독 미흡	경고	(1)
5	●	감찰	DREAMS 시스템 개선	통보	(1)
6	●	감찰	시각동기화 확대방안 강구	통보	(1)
7	●	감찰	子 개선	권고	(1)
8	●	감찰	丑 개선	권고	(1)
9	●	감찰	寅 개선	권고	(1)
10	●	감찰	卯 개선	권고	(1)
11	●	감찰	辰 개선	권고	(1)

2. 처분요구사항 명세 : “별 첨”

한국수력원자력(주) 상임감사위원

경 고 · 시 정

제 목 본사사옥 설비관리용 컴퓨터 계정 미분리 사용

관 계 부 서 ○, ●

내 용

○ □ 甲은 A 설비(○분야)를 대상으로 유지보수 업무를 담당하고, B 설비는 ● ▣ 乙이 유지보수를 하고 있다. 그리고 ●는 '경주본사 신사옥 시설관리 용역'의 유지보수 업체인 'C'를 통해 [표 1] 설비에 대하여 2015. 12. 14.부터 위탁하여 운영하고 있다.

[표 1] 빌딩제어실내 운용설비 리스트 및 담당자

번호	설비명	담당자		번호	설비명	담당자	
		소속	성명			소속	성명
1	a	□	甲	11	k	▣	乙
2	b	□	甲	12	l	▣	乙
3	c	□	甲	13	m	□	甲
4	d	□	甲	14	n	▣	乙
5	e	□	甲	15	o	□	甲
6	f	▣	乙	16	p	□	甲
7	g	□	甲	17	q	□	甲
8	h	▣	乙	18	r	□	甲

번호	설비명	담당자		번호	설비명	담당자	
		소속	성명			소속	성명
9	i	☒	乙	19	s	☐	甲
10	j	☒	乙	20	t	☐	甲

우리 회사 「정보보안업무 세부운용지침」 제33조(사용자 계정 관리)에 따르면, “시스템 관리자는 사용자에게 정보시스템 접속에 필요한 사용자 계정(ID) 부여시 비인가자 도용 및 정보통신시스템 불법접속에 대비하여 사용자별 접근권한을 부여” 하도록 하고 있다.

그러나, 2017. 3. 10. 빌딩제어실내 설치된 20개 빌딩관리용 컴퓨터 설비를 확인한 결과, 관리자(우리회사 담당자)와 사용자(유지보수 업체 담당자)의 계정을 분리하지 않고 동일한 계정을 사용한 것이 확인되었다.

조치할 사항 ●장은 본사 빌딩제어실에 시설된 20개 설비용 컴퓨터에 대하여 관리자 및 사용자 계정을 분리하지 않는 등 업무를 소홀히 한 ○ ☐ 甲 및 ○ ☒ 乙에게 ‘경고’ 처분하시기 바랍니다.(경고)

또한, ○장과 ●장은 본사 빌딩제어실내 컴퓨터 설비에 대하여 관리자 및 사용자 계정을 분리하시기 바랍니다.(시정)

한국수력원자력(주) 상임감사위원

주 의 · 통 보

제 목 △ B 설비 보안관리 미흡

관 계 부 서 ◇

내 용

◇ ▷ 丙은 현재까지 ▷과 △을 대상으로 B 설비에 대한 유지보수와 정보보안 업무를 수행하고 있다.

우리 회사 「정보보안업무 세부운용지침」 제28조(PC 등 단말기 보안관리) 및 제34조(비밀번호 관리)에 따르면, “최신 백신 운용·점검 및 운영체제(OS) 등을 보안 패치를 유지”하도록 명시하고 있다.

△ ‘D 설비’ 로그인 비밀번호를 키보드에 부착하여 사용하고, 운영체제(OS)도 업데이트가 제때에 이루어지고 있지 않으며, 시설된 CCTV 주장치는 원격접속 프로그램이 활성화 되어 있으며, USB 및 LAN 포트 봉인하지 않는 등 업무를 미흡하게 처리하고 있다.

조치할 사항 ◇장은 △ 설비 로그인 비밀번호 관리 및 운영체제 업데이트 미흡 등 보안규정을 소홀히 한 책임을 물어 ▷ 丙에게 ‘주의’ 처분하시기 바랍니다.(주의)

또한, ◇장은 ◇와 사업소 정보보안 규정 준수를 위하여 ① 비밀번호 관리실태 점검, ② 운영체제(OS) 업데이트, ③ 원격접속 비활성화, ④ USB 및 LAN 포트를 봉인하는 등 보안 조치하시기 바랍니다.(통보)

한국수력원자력(주) 상임감사위원

경 고 요 구

제 목 정보시스템 저장매체(HDD) 보안규정 미준수

관 계 부 서 ● 目

내 용

● 目은 ‘정보시스템 유지보수업무 위탁용역’으로 컴퓨터프라자¹⁾를 운영하고 있으며 관리·감독 책임이 있다.

우리 회사는 지난 2016. 7. 감사원 감사시 ‘컴퓨터프라자’에서 표본조사를 위해 무작위로 선정한 50개 하드디스크(HDD)를 회수한 후, 저장매체 불용처리에 대한 문제점을 지적하면서 자체 감사를 요구받았다.

이에, 본 감사기간 동안 50개의 HDD 중에서 인식(복구)이 불가능한 27개와 보안 설정으로 비밀번호를 요구하고 있어 복구에 실패한 16개인 총 43개를 제외하고, 포맷하지 않은 7개를 분석한 결과, 일부 민감한 자료를 포함하고 있는 것이 확인되었다.

우리 회사 「정보보안업무 세부운용지침」 제43조(전자정보 저장매체 불용처리)에 따르면, “자료 삭제는 해당 정보가 복구될 수 없도록 정보시스템 저장매체 불용처리 지침에 따라 차별화된 삭제 방법을 적용하여야 한다”라고 명시하고 있다.

1) 컴퓨터프라자 : 사무자동화 기술지원 업무 등

그러나, 2016. 7. 감사원 감사 당시 컴퓨터프라자에서는 PC 교체 또는 HDD 불량에 따른 사용자 정보를 관리하고 있지 않아 사용자를 특정할 수 없으나(컴퓨터프라자는 감사원 감사 후, 2016. 9.부터 HDD의 사용자 정보를 기록·관리하고 있다.), 포맷하지 않은 HDD의 제조일이 2007. 4. 3.로 표기된 것으로 볼 때, 완전삭제를 미루고 장기간 보관(방치)중이었던 것으로 판단된다.

즉, ● ㉠은 PC 교체 및 불량인 HDD에 대하여 데이터 완전삭제를 하지 않고 복구가 가능한 상태로 보관하고 있는 컴퓨터프라자에 대하여 감독업무를 미흡하게 한 것이다.

조치할 사항 ●장은 컴퓨터프라자의 정보시스템 저장매체(HDD) 데이터 삭제 관리·감독 업무가 미흡한 책임을 물어 ● ㉠에게 ‘경고’처분하시기 바랍니다.(부서경고)

한국수력원자력(주) 상임감사위원

통 보

제 목 DREAMS내 과다한 회사자료 다운로드 관리체계 개선

관 계 부 서 ●

내 용

우리 회사 DREAMS²⁾에는 예산, 계약문서는 물론 원전 도면 등 방대한 자료가 저장되어 있는데, 2016년 월평균 다운로드(단순조회 건수 포함) 건수는 약 106만 건에 달하고 있다.

그러나, DREAMS 사용자가 단순히 조회만 한 것인지 아니면 사용자 PC로 다운로드 된 것인지 관리되지 않고 있어, 만약 불순한 의도를 가지고 과다하게 다운로드 받은 자료를 외부로 유출시킬 경우 그 피해는 고스란히 우리회사의 명예훼손으로 이어질 수밖에 없는 실정이다. 따라서, DREAMS를 통한 다운로드 건수를 관리하도록 시스템을 개선할 필요가 있다.

조치할 사항 ●장은 DREAMS 사용자의 단순 조회건과 PC로의 다운로드를 구분하여 관리하도록 시스템을 개선하고, 일정기간(3~6개월) 경과 후 개별 평균 다운로드 수를 산정하여 필요 이상으로 과다하게 다운로드 받는 자에 대하여 알람창을 띄우는 등 시스템 및 제도 개선하시기 바랍니다.(통보)

2) DREAMS(Digital Realtime Enterprise Asset Management System) : 전사적 자원관리시스템

한국수력원자력(주) 상임감사위원

통 보

제 목 시각동기화 설비 확대적용 방안 강구

관 계 부 서 ●

내 용

정보시스템(전산화설비)으로 제어 및 감시되는 설비에 대하여 표준시각으로 동기화가 되지 않을 경우, 설비장애가 발생할 때 설비간 각기 다른 시각으로 운용되기 때문에 문제해결 및 원인분석을 위한 시간 추적이 불가능하다.

●에서 시설한 B 설비에 대하여 시각동기화를 시키고 있는 반면, 타 처(실)에서 설치한 시스템에는 시각정보를 제공하지 않고 있다. 따라서, 시각동기화 설비를 운용하고 있는 ●는 타 처(실)에서 운용하고 있는 B 설비를 대상으로 시각동기화를 확대하는 방안을 강구할 필요가 있다.

조치할 사항 ●장은 시각동기화 설비를 확대 적용하는 방안을 강구하시기 바랍니다.(통보)

한국수력원자력(주) 상임감사위원

권 고

제 목 정보보안솔루션(5종) 개선

관 계 부 서 ●

내 용

본 감사기간 중 외부전문가에 의한 우리 회사 보안솔루션(7종) 로그 데이터를 분석한 결과, 총 5종의 보안솔루션에 대해서 다음과 같이 개선이 요구된다.

1. 주 개선

2016년 외부망에서 내부망으로 대용량(100MB 이상) 파일을 전송한 건 중에서, 자료전송시 제목으로 무의미한 “1” 또는 “자료전송” 등을 사용하고 있으며, 붙임 파일명도 제목과 관련성이 낮은 문구를 사용하고 있다.

또한, 동영상(*.avi, *.mp4) 및 음악(*.mp3) 파일을 전송하는 경우에는 알려지지 않은 악성코드를 포함하고 있을 확률이 매우 높다.

조치할 사항 ●장은 ① 주 운용시 제목이 한글 기준 12문자 이상으로 하고, 붙임 파일명도 제목과 관련성을 검토 후 승인하도록 하며, ② 동영상/음악 파일 전송시 승인절차를 거치도록 보완하시기 바랍니다.(권고)

2. 丑 개선

우리 회사는 무단으로 인쇄하여 배포하지 못하도록, 자료를 인쇄할 때 회사 로고의 워터마크와 함께 사용자 (일부)정보 등이 표시된다.

조치할 사항 ●장은 丑의 예외정책 승인시 기간과 함께 해제가 필요한 “파일명”으로 제한하여 승인하도록 시스템을 보완하시기 바랍니다.(권고)

3. 寅 개선

우리 회사는 지속적으로 업무와 무관한 사이트를 차단하고 있다.

조치할 사항 ●장은 寅 운용시 접속로그 중에서 전형적인 웹주소 형식 이외의 신규 생성된 웹주소로의 접속을 테스트하고 차단하시기 바랍니다.(권고)

4. 卯 개선

2016년도 본사 卯 로그기록을 확인한 결과, 2회 이상 ‘F’ 실행점수가 미달한 건수는

*대이며, 4회 이상 실행점수 미달 건은 *대에 달하고 있다.

조치할 사항 ●장은 2회 이상 연속적으로 ‘F’ 실행점수가 미달할 경우 네트워크 접속을 차단하시기 바랍니다.(권고)

5. 辰 개선

우리 회사 辰 보안정책상 특정 단어와 확장자명을 사용할 때 승인권자의 승인 후 발송이 가능하다.

조치할 사항 ●장은 辰의 특정 단어(aa, bb 등)를 추가하고 해당 자료의 외부 발송시 부서장 승인 후 전송되도록 조치하시기 바랍니다.(권고)